

PeerLink / P2P — NGINX, Server Header, CSP, and Form Validation Remediation

Professional remediation summary and verification for four production web security findings: outdated NGINX version, web server version/header disclosure, Content-Security-Policy coverage, and application form/input validation hardening.

APPLICATION

PeerLink / P2P

PRODUCTION DOMAIN

p2p.iotsolutions.sa

PUBLIC IP

145.241.154.18

Executive Summary

This report documents remediation and verification for four externally reported security items on the PeerLink production web application. The review covers the public HTTPS endpoint, the production NGINX edge configuration, CSP/header behavior, and application-level input/form validation hardening.

FINDING 1

Resolved

NGINX has been upgraded from the previously reported 1.24.x line to nginx/1.30.3.

FINDING 2

Resolved

Public responses no longer expose the Server response header on tested routes.

FINDING 3

Resolved / Present

Content-Security-Policy is present on the tested HTTPS application and API routes.

FINDING 4

Resolved

Application forms and API inputs were hardened against junk input, XSS payloads, unsafe URLs, invalid categories, and regex/search abuse.

Finding	Previous Concern	Current Verified State	Status
Outdated NGINX	NGINX 1.24.x reported as outdated/vulnerable.	Production host reports nginx/1.30.3 .	Resolved
Web Server Version / Header Disclosure	Public response disclosed web server details.	Public tests across <code>/</code> , <code>/home</code> , <code>/login</code> , and <code>/api/health</code> show Server header count: 0 .	Resolved
Missing Content-Security-Policy	CSP response header was reported missing or incomplete.	CSP is present on tested routes and includes baseline hardening directives such as <code>default-src 'self'</code> , <code>script-src 'self'</code> , <code>object-src 'none'</code> , <code>base-uri 'self'</code> , <code>form-action 'self'</code> , and <code>frame-ancestors 'self'</code> .	Resolved
Application Form / Input Validation	Forms accepted suspicious input, symbol-heavy junk strings, URLs in inappropriate fields,	Backend and frontend validation now covers forum posts, use-case submission/drafts,	Resolved

Finding	Previous Concern	Current Verified State	Status
	scanner payloads, and unsafe search/query input.	profile/dashboard inputs, uploads, search parameters, nested use-case architecture fields, and frontend map popup rendering.	

Scope and Verification Method

The verification covered the public production domain and core public routes. The verification includes server-side package/version checks, NGINX configuration validation, public HTTP header checks, and live HTTPS response checks.

- Production domain tested: **https://p2p.iotsolutions.sa**
- Public IP verified: **145.241.154.18**
- Tested public routes: `/`, `/home`, `/login`, `/api/health`
- Application validation scope: **backend and frontend input validation hardening, XSS prevention, and safe search handling**
- Verification dates: **15–18 June 2026**

Finding 1 — Outdated NGINX Version

Result

Resolved

The production web server was upgraded to **nginx/1.30.3**. Package policy output confirms the installed NGINX version is 1.30.3 from the nginx.org package repository for Ubuntu Noble on arm64.

Verified version: nginx/1.30.3
Installed package: 1.30.3-1~noble
Architecture: arm64

This addresses the prior outdated NGINX 1.24.x finding by moving the production edge to a current upstream NGINX release.

Fix 1 verification — NGINX package version

Package verification confirms the production edge is running nginx/1.30.3.

```
P2P / PeerLink live NGINX 1.30.3 evidence
Generated: 2026-06-18 13:23:02 AST / UTC+3
Domain: https://p2p.iotsolutions.sa
OCI IP: 145.241.154.18

$ ssh ubuntu@145.241.154.18 nginx -v
nginx version: nginx/1.30.3

$ ssh ubuntu@145.241.154.18 "dpkg -l nginx | awk 'NR==1 || /^ii/'"
Desired=Unknown/Install/Remove/Purge/Hold
ii  nginx                  1.30.3-1-noble arm64      high performance web server

$ ssh ubuntu@145.241.154.18 "sudo nginx -T | grep hardening lines"
2:load_module modules/nginx_http_headers_more_filter_module.so;
23:     server_tokens off;
25:     more_clear_headers Server;
250:    add_header Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net; font-src 'self' https://cdn.jsdelivr.net data;; img-src 'self' data: blob: https;; connect-src 'self' https://p2p.iotsolutions.sa wss://p2p.iotsolutions.sa; media-src 'self' blob: https;; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'self'" always;

$ ssh ubuntu@145.241.154.18 "sudo nginx -t && systemctl is-active nginx"
active
nginx: [warn] the "listen ... http2" directive is deprecated, use the "http2" directive instead in /etc/nginx/sites-enabled/p2p:10
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful

$ curl -sI https://p2p.iotsolutions.sa/home
HTTP/2 200
date: Thu, 18 Jun 2026 10:23:06 GMT
content-type: text/html
content-length: 1552
last-modified: Thu, 18 Jun 2026 10:06:14 GMT
etag: "6a33c316-610"
accept-ranges: bytes
strict-transport-security: max-age=31536000
content-security-policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net; font-src 'self' https://cdn.jsdelivr.net data;; img-src 'self' data: blob: https;; connect-src 'self' https://p2p.iotsolutions.sa wss://p2p.iotsolutions.sa; media-src 'self' blob: https;; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'self'

$ curl -sI https://p2p.iotsolutions.sa/home | awk server-header-count
Server header count: 0

$ curl -sk https://p2p.iotsolutions.sa/api/v1/health/
{"status":"healthy","timestamp":"2026-06-18T10:23:06.631179","version":"1.0.0","uptime":1779805403.0,"checks":{"api":"healthy","postgresql":"healthy","mongodb":"healthy"}}
```

Finding 2 — Web Server Version / Header Disclosure

Result

Resolved

The public `Server` response header is no longer present on the tested public routes. Verification checks show a Server header count of zero across the root page, home page, login page, and API health route.

```
/ Server header count: 0
/home Server header count: 0
/login Server header count: 0
/api/health Server header count: 0
```

The NGINX configuration also keeps `server_tokens off` enabled. This prevents detailed version disclosure if a product token is ever emitted by a future configuration change.

Fix 2 configuration verification — server tokens, Server header clearing, and CSP

Configuration verification shows server token suppression, response-header clearing, CSP header injection, and a successful NGINX syntax test.

```
P2P / PeerLink Evidence 02 - NGINX config has Server removal + CSP + valid syntax
Generated: 2026-06-15 13:17:24 +03

$ ssh ubuntu@145.241.154.18 "sudo nginx -T 2>/dev/null | grep -nE \"load_module|server_tokens|more_clear_headers|Content-
Security-Policy\"; ls -l /usr/lib/nginx/modules/nginx_http_headers_more_filter_module.so; sudo nginx -t"
2:load_module modules/nginx_http_headers_more_filter_module.so;
23:     server_tokens off;
25:     more_clear_headers Server;
259:     add_header Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'
https://cdn.jsdelivr.net; font-src 'self' https://cdn.jsdelivr.net data;; img-src 'self' data: blob: https;; connect-src
'self' https://p2p.iiootsolutions.sa wss://p2p.iiootsolutions.sa; media-src 'self' blob: https;; object-src 'none'; base-uri
'self'; form-action 'self'; frame-ancestors 'self'" always;
-rw-r--r-- 1 root root 258520 Jun 15 09:40 /usr/lib/nginx/modules/nginx_http_headers_more_filter_module.so
nginx: [warn] the "listen ... http2" directive is deprecated, use the "http2" directive instead in /etc/nginx/sites-
enabled/p2p:10
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
```

Fix 2 public verification — Server header removed

Public route checks show the Server response header count is zero on the tested application and API routes.

```
P2P / PeerLink Evidence 03 - Public Server header removed
Generated: 2026-06-15 13:17:24 +03

$ curl -skI https://p2p.iiootsolutions.sa/ | awk 'BEGIN{IGNORECASE=1} /^server:/ {c++} END{print "/ Server header count:", c+0}'
/ Server header count: 0
$ curl -skI https://p2p.iiootsolutions.sa/home | awk 'BEGIN{IGNORECASE=1} /^server:/ {c++} END{print "/home Server header count:", c+0}'
/home Server header count: 0
$ curl -skI https://p2p.iiootsolutions.sa/login | awk 'BEGIN{IGNORECASE=1} /^server:/ {c++} END{print "/login Server header count:", c+0}'
/login Server header count: 0
$ curl -skI https://p2p.iiootsolutions.sa/api/health | awk 'BEGIN{IGNORECASE=1} /^server:/ {c++} END{print "/api/health Server header count:", c+0}'
/api/health Server header count: 0
```

Finding 3 — Content-Security-Policy Header

Result

Resolved / Present

The public application now returns a Content-Security-Policy header on the tested HTTPS application and API routes. The policy restricts scripts to same-origin, blocks plugin/object execution, limits form submission and base URI behavior, and limits framing to same-origin.

```
default-src 'self';
script-src 'self';
style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net;
font-src 'self' https://cdn.jsdelivr.net data;
```

```
img-src 'self' data: blob: https;;
connect-src 'self' https://p2p.iiootsolutions.sa wss://p2p.iiootsolutions.sa;
media-src 'self' blob: https;;
object-src 'none';
base-uri 'self';
form-action 'self';
frame-ancestors 'self'
```

Fix 3 public verification — CSP header present

Public route checks show Content-Security-Policy is present on the tested application and API routes.

```
P2P / PeerLink Evidence 04 - Public CSP header present
Generated: 2026-06-15 13:17:26 +03

$ curl -s -kI https://p2p.iiootsolutions.sa/home | awk 'BEGIN{IGNORECASE=1} /^content-security-policy:/ {print}'
content-security-policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net;
font-src 'self' https://cdn.jsdelivr.net data:; img-src 'self' data: blob: https;; connect-src 'self'
https://p2p.iiootsolutions.sa wss://p2p.iiootsolutions.sa; media-src 'self' blob: https;; object-src 'none'; base-uri 'self';
form-action 'self'; frame-ancestors 'self'

$ curl -s -kI https://p2p.iiootsolutions.sa/login | awk 'BEGIN{IGNORECASE=1} /^content-security-policy:/ {print}'
content-security-policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net;
font-src 'self' https://cdn.jsdelivr.net data:; img-src 'self' data: blob: https;; connect-src 'self'
https://p2p.iiootsolutions.sa wss://p2p.iiootsolutions.sa; media-src 'self' blob: https;; object-src 'none'; base-uri 'self';
form-action 'self'; frame-ancestors 'self'

$ curl -s -kI https://p2p.iiootsolutions.sa/api/health | awk 'BEGIN{IGNORECASE=1} /^content-security-policy:/ {print}'
content-security-policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net;
font-src 'self' https://cdn.jsdelivr.net data:; img-src 'self' data: blob: https;; connect-src 'self'
https://p2p.iiootsolutions.sa wss://p2p.iiootsolutions.sa; media-src 'self' blob: https;; object-src 'none'; base-uri 'self';
form-action 'self'; frame-ancestors 'self'
```

Finding 4 — Application Form and Input Validation

Result

Resolved

Application-layer input validation and XSS hardening have been added across the relevant backend schemas, API endpoints, and frontend form/popup rendering paths. The completed work addresses the prior concern that application forms accepted suspicious or meaningless values.

Fix 4.1 — Central backend safe-text validation

User-controlled text now passes through validation that rejects dangerous patterns such as script tags, `javascript:` payloads, path traversal, null bytes, scanner strings, excessive symbols, repeated-character junk, and meaningless values.

Fix 4.2 — Profile and dashboard input validation

Profile names, job title/location fields, expertise tags, dashboard draft fields, post type, category, and related user-editable fields are constrained by validation rules and allowlists.

Profile edit validation

The profile form blocks invalid name characters, HTML-like location input, and invalid expertise tag values before saving.

PeerLink - Saudi Manufacturing X +

Ask Gemini

p2p.liotsolutions.sa/dashboard

Edit Profile

Profile Information Account Settings

Upload Photo

JPEG, PNG, or WebP • Max 5MB

First Name Last Name

Hamza@ Feroze

Name can only contain letters, spaces, hyphens, and apostrophes

Job Title

AI Developer

Company

liotsolutions

Industry Sector

Technology

Location

<SCF>

HTML tags are not allowed in this field

Expertise Tags

tag!

Tags can only contain letters, numbers, spaces, and hyphens

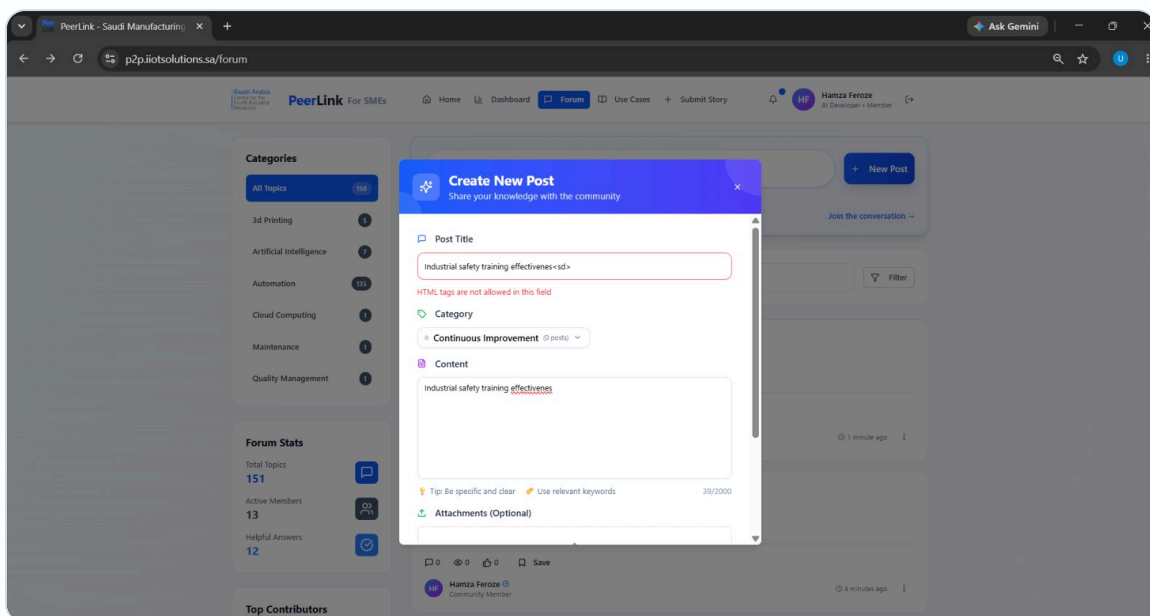
Save Profile Cancel

Fix 4.3 — Forum form validation

Forum post titles, content, tags, category values, replies, and query parameters are validated with length limits, allowed categories/sort values, safe text checks, and strict pagination bounds.

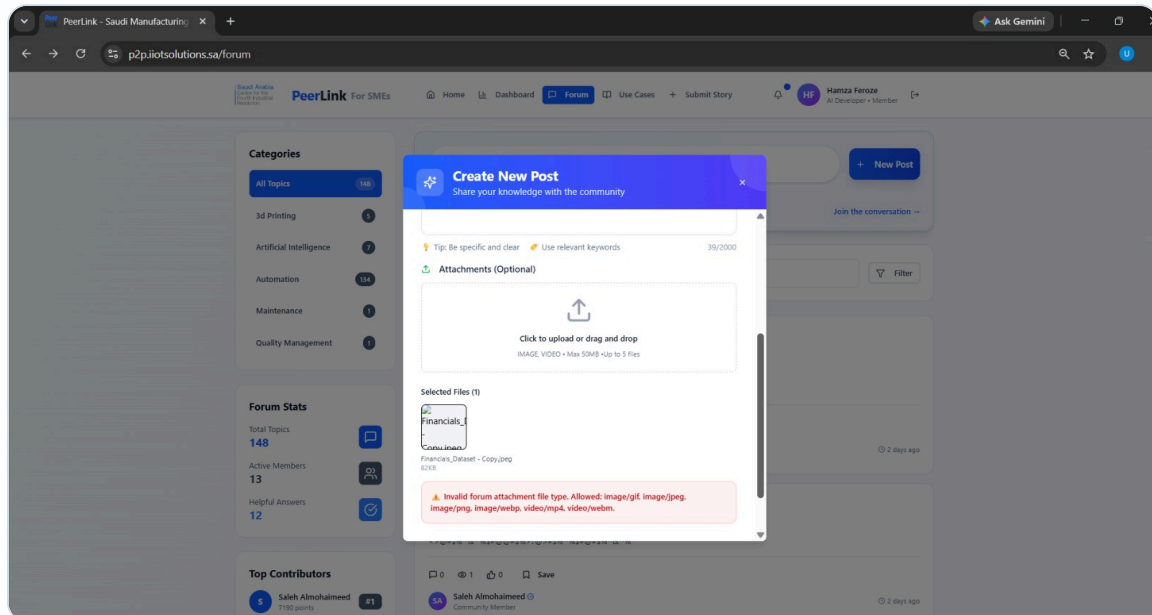
Forum post title HTML validation

The forum post form rejects HTML tag input in the title field and shows a clear validation message.



Forum attachment type validation

The forum attachment flow rejects unsupported file types while showing the allowed image/video formats.



Fix 4.4 — Use-case submission and draft validation

Use-case submission fields and draft payloads enforce safe text validation, valid categories, safe nested values, bounded list sizes, and protection against unsafe payloads while preserving legitimate draft auto-save behavior.

Use-case title special-character validation

The Submit Story form rejects symbol-heavy input in the use-case title field.

The screenshot shows the 'Basic Information' section of the 'Submit Story' form. The 'Use Case Title' field (10-100 chars) contains the text 'Industrial safety training effectiveness' and is highlighted with a red border. Below the field, a red error message states: 'Too many special characters are not allowed in titles'. The 'Subtitle' field (10-150 chars) contains the same text. The 'Category' dropdown is set to 'Predictive Maintenance'. The 'Factory Name' field (2-80 chars) contains 'BzTecq'. The 'Executive Summary' field (10-500 chars) contains a paragraph about Apex Electronics. The form is displayed on a web browser with the URL 'p2p.iotsolutions.sa/submit'.

Use-case URL and repeated-character validation

The Submit Story form blocks URLs in restricted fields and flags repeated-character junk input in the summary field.

The screenshot shows the 'Basic Information' section of the 'Submit Story' form. The 'Use Case Title' field (10-100 chars) contains the text 'Industrial safety training effectiveness' and is highlighted with a red border. Below the field, a red error message states: 'Too many special characters are not allowed in titles'. The 'Subtitle' field (10-150 chars) contains the text 'www.attacker.com' and is highlighted with a red border. Below the field, a red error message states: 'URLs and links are not allowed in this field'. The 'Category' dropdown is set to 'Predictive Maintenance'. The 'Factory Name' field (2-80 chars) contains 'BzTecq'. The 'Executive Summary' field (10-500 chars) contains a paragraph about Apex Electronics. The form is displayed on a web browser with the URL 'p2p.iotsolutions.sa/submit'.

Fix 4.5 — Nested architecture, search, uploads, and frontend XSS prevention

- **Nested technical architecture fields:** `security_measures` and `scalability_design` are now validated item-by-item so XSS/security payloads cannot bypass checks through nested arrays.
- **Search endpoint hardening:** search accepts short legitimate manufacturing terms such as `AI`, rejects URLs/security payloads, and escapes user text before building MongoDB regular expressions. This prevents regex-style input such as `abc.*` from becoming an unintended broad regex query.
- **Upload metadata:** client-provided file names and upload metadata are checked before persistence so unsafe strings cannot be stored through upload flows.
- **Form-side validation:** frontend validation blocks obvious dangerous patterns, URLs in fields where links are not allowed, excessive special characters, repeated characters, and meaningless strings before submission.
- **Backend/frontend consistency:** the frontend consecutive-consonant rule was aligned with backend behavior so legitimate manufacturing text is not rejected too aggressively by the browser before the backend can validate it.
- **Map popup XSS prevention:** Leaflet popup HTML now escapes user-controlled values before injecting them into raw HTML strings, preventing malicious values from breaking out of attributes or injecting scriptable content.

Files covered by the validation remediation

```
p2p-backend-app/app/core/input_validation.py
p2p-backend-app/app/core/upload_validation.py
p2p-backend-app/app/schemas/forum.py
p2p-backend-app/app/schemas/usecase.py
p2p-backend-app/app/api/v1/endpoints/forum.py
p2p-backend-app/app/api/v1/endpoints/usecases.py
p2p-backend-app/app/api/v1/endpoints/dashboard.py
p2p-backend-app/app/api/v1/endpoints/auth.py
p2p-frontend-app/src/components/ui/CreatePostModal.tsx
p2p-frontend-app/src/pages/SubmitUseCase.tsx
p2p-frontend-app/src/components/InteractiveMap.tsx
p2p-frontend-app/src/components/UseCasePopup.tsx
```

Validation checks

```
Backend compile checks: passed
Nested XSS validation checks: passed
Search validation checks: AI accepted, URLs/script payloads rejected, regex
```

input escaped
Frontend TypeScript compile: passed

Current Public Header Snapshot

A fresh public header check on the home route confirms the current security posture:

```
HTTP/2 200
Strict-Transport-Security: max-age=31536000
Content-Security-Policy: present
Server header: not present
```

Final public verification — HTTPS/HTTP2 response

A public HTTPS check confirms the site responds successfully after the remediation changes.

```
P2P / Peerlink Evidence 05 - Public site responds
Generated: 2026-06-15 13:17:27 +03

$ curl -skI https://p2p.iiootsolutions.sa/ | head -n 8
HTTP/2 200
date: Mon, 15 Jun 2026 10:17:27 GMT
content-type: text/html
content-length: 1552
last-modified: Wed, 10 Jun 2026 10:04:48 GMT
etag: "6a2936c0-610"
accept-ranges: bytes
strict-transport-security: max-age=31536000

$ curl -skI https://p2p.iiootsolutions.sa/home | head -n 8
HTTP/2 200
date: Mon, 15 Jun 2026 10:17:27 GMT
content-type: text/html
content-length: 1552
last-modified: Wed, 10 Jun 2026 10:04:48 GMT
etag: "6a2936c0-610"
accept-ranges: bytes
strict-transport-security: max-age=31536000

$ curl -skI https://p2p.iiootsolutions.sa/login | head -n 8
HTTP/2 200
date: Mon, 15 Jun 2026 10:17:28 GMT
content-type: text/html
content-length: 1552
last-modified: Wed, 10 Jun 2026 10:04:48 GMT
etag: "6a2936c0-610"
accept-ranges: bytes
strict-transport-security: max-age=31536000

$ curl -skI https://p2p.iiootsolutions.sa/api/health | head -n 8
HTTP/2 404
date: Mon, 15 Jun 2026 10:17:28 GMT
content-type: application/json
content-length: 22
strict-transport-security: max-age=31536000
```

Conclusion

The reviewed issues have been addressed on the production PeerLink/P2P application and web edge:

- NGINX has been upgraded to **1.30.3**.
- The public `Server` response header is absent on tested routes.
- The public `Content-Security-Policy` header is present and includes appropriate baseline protections.
- Application forms and API inputs have been hardened with validation controls for profile, forum, use-case, upload, search, and frontend rendering paths.